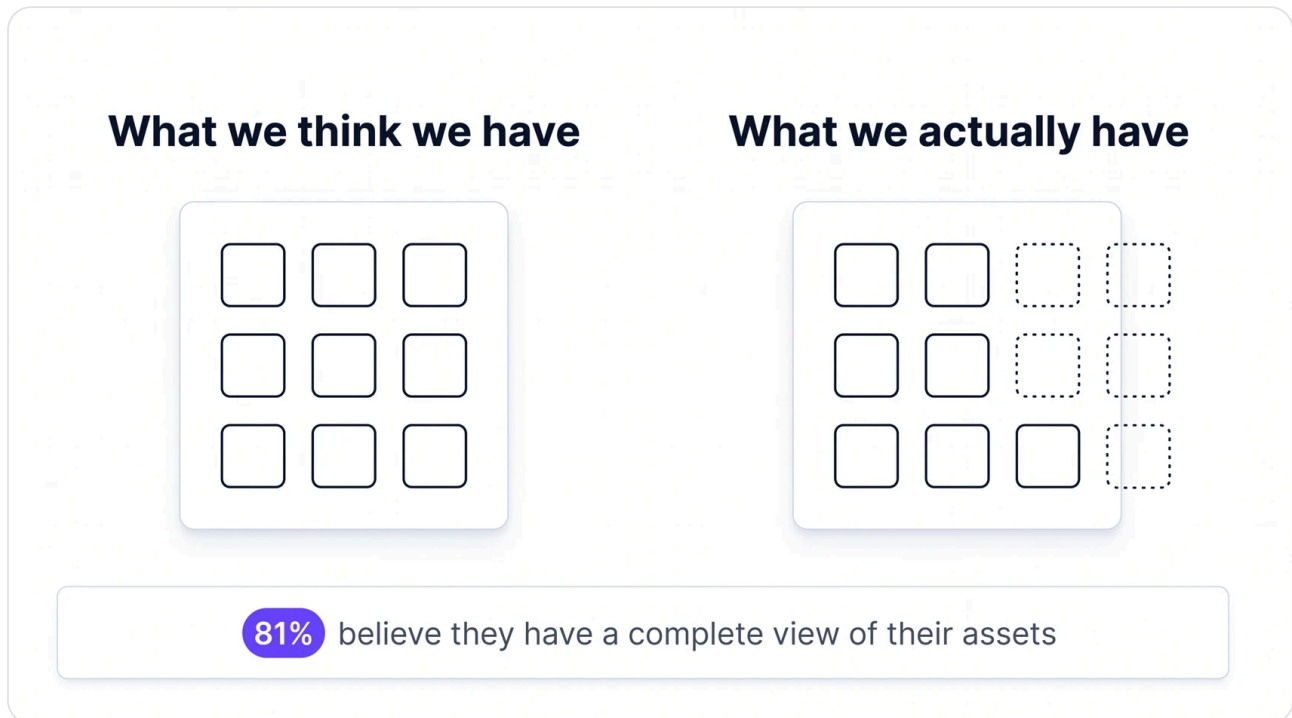


The CISO's briefing: The asset inventory

What is not inventoried does not exist, until the day it exists too much



The gap between what one believes one holds and what one holds.

Session objectives

By the end of this sequence:

- **Explain** what an asset inventory is, what distinguishes it from an equipment list, and why nobody is ever done with it
- **Define** what a critical asset is and defend a prioritization before a committee
- **Recognize** shadow IT and shadow AI as inventory holes, and reason about their treatment in terms of governance rather than prohibition
- **Arbitrate** as Group CISO a concrete question: who keeps the inventory, and what is done with what does not appear in it?

Prerequisites

- The governance laid down in session 1: the three decision levels, the single-accountable RACI matrix, the Group CISO's inter-subsidiary arbitration.
- The principle of least privilege and defense in depth, worked on in session 1: an unknown asset escapes both.

- No notion from this morning's lecture is needed: this CISO's briefing is handled with what session 1 established.

What must be laid down before the exercise

Three notions, a quarter of an hour, and the rest belongs to the pen.

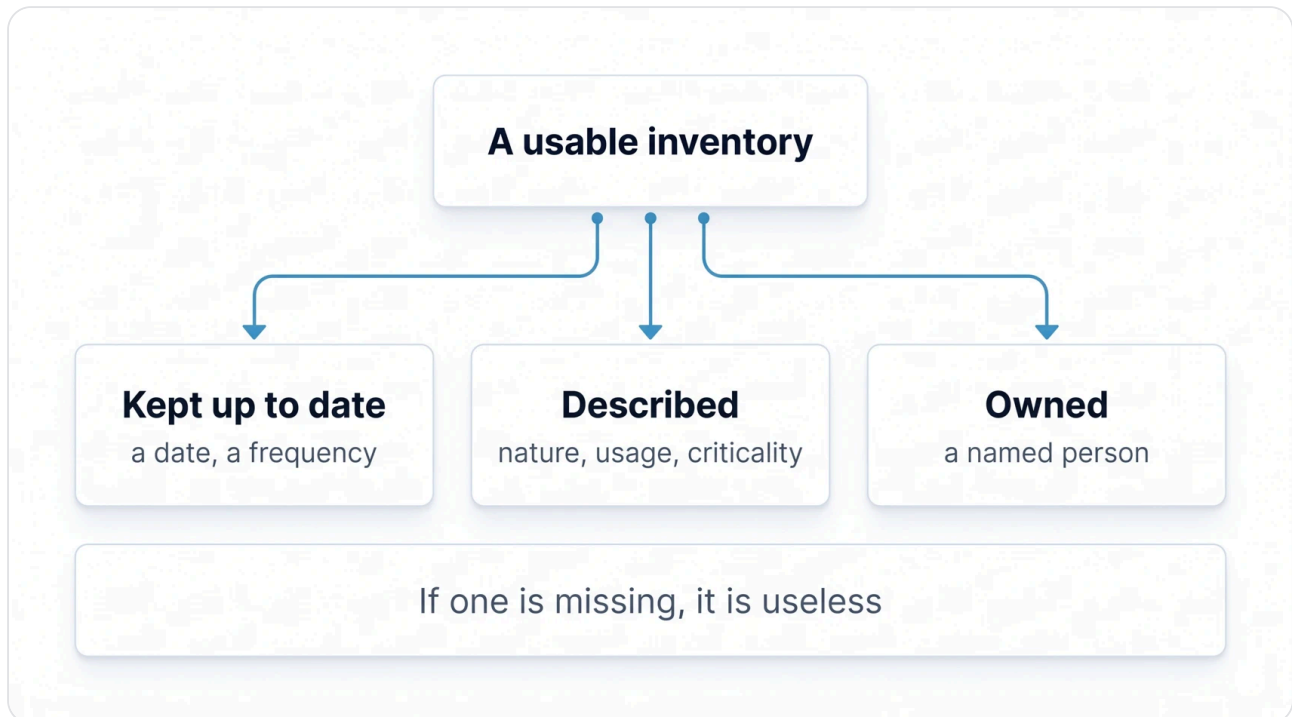
The asset inventory first. The problem it addresses is security's oldest: one does not protect what one does not know one owns. A firewall does not filter the flows of a server whose existence nobody has recorded, a patching policy does not patch an application the IT department has never seen go by. The asset inventory is the kept-up-to-date census of what makes up the information system, each element being described and attached to an owner. Three words of this definition do all the work. "Kept up to date": an inventory is a process, not a document; one dating back eighteen months is an archive. "Described": a line "SRV-042" with no role and no owner teaches nobody anything, least of all on the evening of an incident. "Owner": an asset without an owner is an asset whose drift nobody will notice. And the limit, which must be known so as not to sell the inventory as a magic potion: taking a census is not protecting. The inventory is the precondition of every measure, it is none of them by itself.

The gap between what organizations believe and what they equip gives the measure of the problem. In its barometer published in 2026, CESIN notes that 81 % of companies think they have a complete view of their assets. But the same CESIN published in 2025 a second survey, separate from the barometer and devoted this time to attack surface management. It shows that 73,9 % of CESIN respondents do not have tools allowing them to reconcile the IT and cyber sources present in their information systems. The two figures are read together: eight organizations in ten declare themselves clear, while nearly three quarters lack the technical means to verify it. This confidence without an instrument has a name in governance: a blind spot. It is exactly the kind of gap a CISO must know how to show management without humiliating anyone, and it is today's exercise.

The critical asset next. Not all assets are equal, and an inventory that does not rank produces the most dangerous egalitarianism there is: protecting everything a little means protecting nothing really. A critical asset is an asset whose compromise or unavailability would prevent the organization from accomplishing its mission, the one that makes it exist. The word "mission" is the pivot: criticality is not read off a server's spec sheet, it is deduced from what the business would lose. An innocuous NAS becomes critical the day it is discovered to host the operating theater schedules. The notion's limit, symmetrical: "critical" is not a permanent stamp; a criticality is reassessed when activities move, and a list where everything is critical is a list where nobody had the courage to choose.

Shadow IT and shadow AI finally, because they are the modern form of the inventory hole. Shadow IT refers to the digital tools, applications, online services, subscriptions, put into service by teams without going through the IT department or security; shadow AI is its youngest sibling; artificial intelligence tools used without approval, often fed with internal data. Neither is born of malice: they are born of a real business need that the official offering does not satisfy fast enough. But they share the same structural defect, being invisible to every defense, and the current figures are severe: according to IBM's Cost of a Data Breach report published in 2025, one organization in five reports a data breach due to shadow AI, and organizations with high shadow AI suffer an average extra cost of 670 000 dollars per breach. The limit to remember before drawing the prohibitions: shadow IT thrives where governance is slow; treating it with sanctions alone pushes it deeper into the shadows. It is a question of arbitration, hence a question for the Group CISO.

Before management, never say "we have shadow IT" the way one confesses a fault, but: "our inventory has measurable blind spots, here is how they are being reduced". The first statement calls for a culprit, the second calls for a budget.



The three words of a usable inventory.

Case study: the Éducation & Territoires division's inventory

Scenario and problem statement

Tuesday, 9:05 a.m. While preparing the mapping session planned with the subsidiaries, the Group CISO asked each of them for its inventory. Three replies have arrived. MERIDIAN Santé sends an export from its fleet management tool, dated last month, without the laboratory analyzers or the imaging consoles. MERIDIAN Logistique replies "it is in the Operations Manager's head, he knows his six warehouses by heart". The Éducation & Territoires division, whose IT department is pooled between the two subsidiaries, sends an honest spreadsheet accompanied by an embarrassed email from the Éducation IT Director: while compiling it, his team discovered eleven subscriptions to online services taken out directly by teaching teams, outside the IT department, including a generative AI tool where teachers have student assessments proofread. Limited budget, tens of thousands of users, varied third-party software: the Éducation subsidiary combines all the conditions for the phenomenon.

The governance question to settle before Thursday's committee: **who keeps the group's inventory, under which rules, and what is done with the eleven discoveries?**

Guided questions

1. **Analyze** the three replies received: for each, state what it reveals about the subsidiary's inventory maturity and the main risk it leaves open (hint: the three load-bearing words of the definition, kept up to date, described, owner).
.....
2. **Distinguish**, among the eleven discoveries of the Éducation & Territoires division, what falls under ordinary shadow IT and what falls under shadow AI, and explain how the second case aggravates the data question.
.....
3. **Propose** the treatment of the eleven services: which to document and regularize, which to supervise, which to close, and by what generic criterion (not service by service: the criterion).
.....
4. **Assign** the inventory responsibilities in a mini-RACI: who is responsible for keeping it (R), who is accountable (A), who is consulted, who is informed, at the three levels seen in session 1 (group, subsidiary, operational).
.....
5. **Formulate** the governance rule to propose on Thursday, in one single sentence, applicable to all four subsidiaries, addressing both the keeping of the inventory and the fate of what does not appear in it.
.....

Working method

Allow 10 minutes for questions 1 and 2, 10 for questions 3 and 4, 5 for question 5. The work is done as Group CISO, not as auditor: the auditor records gaps, the CISO additionally proposes a path that accounts for the subsidiaries' real resources, Éducation's limited budget included. For question 4, session 1's discipline applies: one single A per row, and beware the reflex of loading everything onto the Group CISO, which would make that role the bottleneck of the entire group.

Answer keys and assessment criteria

Reasoned answer key

Question 1. Santé has a tool but a truncated perimeter: the export ignores the laboratory analyzers and imaging consoles, which have nevertheless been on the same IP range as office computing since the MERIDIAN dossier's initial audit finding. That is the trap of "described": the inventory covers what the fleet tool knows how to see, and the biomedical equipment escapes it; the open risk is believing complete a census that structurally is not. Logistique has no inventory, it has a memory: the Operations Manager's. The risk is not incompetence, this man genuinely knows his warehouses, it is non-transmissibility: the day he is absent, on leave or gone to a competitor, the knowledge of the information system leaves with him; "kept up to date" presupposes a medium that survives individuals. Éducation & Territoires, paradoxically, produced the best reply: an inventory that is dated, honest, and that DISCOVERED its own holes. An inventory that surfaces eleven unknowns is working; one that never surfaces any is suspect. The remaining risk is downstream: that the discovery leads to nothing.

Question 2. Ten of the eleven services fall under ordinary shadow IT: online tools subscribed to outside the IT department, invisible to filtering and backups, but whose data remains whatever is put into them. The generative AI tool belongs to shadow AI and changes category for a precise reason: student assessments, personal data by nature, are sent to a third-party service whose terms nobody has read, outside any processing register. Shadow IT creates an infrastructure blind spot; shadow AI adds to it a data leak ORGANIZED by the usages themselves, with no compromise needed. That is what IBM measures: the breach comes from a tool nobody was watching, not from a sophisticated attacker.

Question 3. The expected criterion rests on two questions put to each service: what data passes through it, and does an approved alternative exist? Innocuous data and a useful service with no internal equivalent: document, attach an owner, regularize. Sensitive data but a real business need: supervise, that is, migrate to a validated tool or contract with the supplier, with a deadline. Personal or strategic data on a service where no contractual commitment is possible, the generative AI tool first among them: close the usage, and above all OPEN an answer to the need, because the teachers' proofreading need, for its part, will not close. An answer key that bans all eleven services in one stroke misses half the profession: shadow IT is always reborn from flat prohibition.

Question 4. A defensible distribution: at the operational level, each subsidiary is R for keeping its inventory, in the common tool and according to the common nomenclature; at the tactical level, the subsidiary CISO (or the IT Director for the pooled division) is A for completeness and freshness on their perimeter, they are the one who reports; at the strategic level, the Group CISO is consulted on the rules and informed of gaps, and becomes the decider again only on inter-subsidiary assets, in line with the arbitration prerogatives of session 1. The classic error, announced in the method: making the Group CISO the universal A. Four subsidiaries, thousands of assets: a single A at the top is a waiting line, not governance.

Question 5. A formulation that holds: "Each subsidiary keeps its inventory in the common repository with a named owner per asset; any element discovered outside the inventory is attached or dealt with within thirty days, and discovery is valued, never punished." The three pieces count: the keeping rule, the off-list rule with its deadline, and the incentive, without which the Éducation & Territoires division will be the last subsidiary ever to surface its holes. The wording may differ; it must cover these three functions.

Assessment matrix

CRITERION	INSUFFICIENT	EXPECTED	EXCELLENT
Reading of the three replies	A global judgment ("it is incomplete")	A distinct diagnosis per subsidiary, grounded in the definition	Same, and the Éducation & Territoires reply recognized as the most mature despite its holes
Shadow IT / shadow AI	The eleven services treated as one block	The distinction made, the personal data case isolated	Same, with the explicit link between ungoverned usage and a breach without an attacker
Proposed treatment	Blanket prohibition or laissez-faire	A generic criterion in two questions, three possible outcomes	Same, with the answer to the business need that created the shadow
Mini-RACI	The Group CISO carries everything	Three distinct levels, one single A per row	Same, with the bottleneck argument formulated
Governance rule	A wish ("the inventory must be kept up to date")	One applicable sentence covering keeping and off-list	Same, with the incentive mechanism for discovery